AutoVet: What Was Fixed

Security and quality audit - fixes explained in plain terms

Prepared 14 October 2026 | Branch: Seb1 | Backend (Laravel) + Admin and Portal apps

At a glance

16
code updates
all pushed to GitHub

52
automated checks
all passing

0
known risky libraries
in the live apps

1
dashboard request
instead of 9

The whole system was checked for security holes, data leaks, broken features and messy code. This document lists what was fixed, in everyday language. Every item below is already live (backend on Render, admin app on Vercel).

How to read the "Risk before" column: Critical = anyone could break in; High = a real person could misuse it or see private data; Medium = harder to abuse, or causes errors; Low = tidy-up.

1. Logging in and accounts

The most serious problems were here.

Problem (before)	What we changed	Risk before
Someone who only knew the email of a pet owner who had asked to delete their account could log in as them - no password needed.	The password is now always checked first, before anything else.	Critical
The login screen gave different answers for "wrong password", "no such email", "suspended", etc. This let outsiders find out who has an account.	All failed logins now show the same message.	Medium
Anyone could delete another person's unfinished sign-up just by registering with their email.	Registration no longer deletes anything. An old unfinished sign-up is only replaced after the email link is clicked.	High
Suspended clients, deactivated staff and switched-off clinics could keep using the system until they logged out.	Every request now checks the account status. Blocked accounts are stopped right away.	High
Google sign-in accepted login tokens made for other apps, and did not check that the email was verified.	Google sign-in now only accepts tokens issued to AutoVet, with a verified email.	Medium
Passwords typed during sign-up were written to the server log in plain text.	Logs only record which fields had errors, never the values.	High
Resetting or changing a password left old sessions logged in.	Other sessions are signed out when the password changes.	Medium
Login sessions lasted 30 days.	Sessions now last 7 days (adjustable with SANCTUM_EXPIRATION).	Low
A public page let anyone check whether an email was registered and its status.	That page was removed.	Medium

2. Who can do what (staff roles)

Problem (before)	What we changed	Risk before
A veterinarian could create clinic admins, make themselves an admin, and reset an admin's password.	Accounts can only manage roles below them. Clinic admins can manage up to clinic admin. Nobody can change their own role.	High
Any clinic's staff could download a backup containing every clinic's data.	Backups now only contain your own clinic. Only the super admin gets the full backup.	High
Vets could restore or permanently delete archived staff accounts.	Only admins can manage archived accounts.	Medium
Super admin "login as clinic" tokens never expired and were not recorded.	They expire after 1 hour and every use is written to the audit log.	Medium

3. Pet owner portal limits

Problem (before)	What we changed	Risk before
A client could book an appointment as "approved" or "completed", skipping the clinic.	Client bookings always start as "pending".	High
A client could change their appointment to approved, or move it.	Clients can only cancel their own upcoming appointment.	High
A client could create a medical record (diagnosis) and put a vet's name on it.	Only vets and clinic admins can write medical records.	High
A client could look up any other client's name by phone number or email.	That lookup is now staff-only.	High
Clients could open invoices that were still drafts.	Draft invoices are hidden from clients.	Low

4. Keeping private data private

Problem (before)	What we changed	Risk before
A staff member and a client with the same ID number could see each other's notifications.	Notifications are now stored separately for staff and clients.	High
Clients received the full staff record of the vet (email, status, internal flags).	Clients now only see the vet's name.	Medium
Error messages could show database details and file paths.	Users now see a clear, simple message. Technical details stay in the server log.	Medium
The public reviews list included internal ID numbers.	It now only shows what the landing page displays.	Medium
Clients could read every clinic setting and unpublished website content.	Clients only get the clinic letterhead details and published content.	Low
A public status page revealed whether the database was reachable.	It now only says "ok".	Low
Security headers were missing on some pages, and the server advertised its software.	Security headers are on every response; the software name is hidden.	Low

5. Keeping clinics separate

Important if more than one clinic uses AutoVet.

- Staff can no longer attach appointments, records or invoices to another clinic's pets or owners by guessing an ID.
- Dashboard numbers, charts and live updates are now kept per clinic (before, one clinic could see another clinic's figures).
- Reviews are now per clinic - a clinic admin can no longer approve or delete another clinic's reviews.

6. Lists and page numbers (pagination)

Problem (before)	What we changed
Going from page 1 to 2 to 3 and pressing Back took you to the dashboard instead of the previous page. Refreshing also went back to page 1.	The page number is now in the web address (for example ?page=3). Back goes to the previous page and refresh keeps your page. Applied to Patients, Pets, Inventory, Invoices, Notification history, patient profile tabs and Settings tables.
A list could be asked for a million rows at once, slowing the server down.	Lists now return at most 100 rows per page (1,000 for small dropdown lists). Screens that need everything load it page by page.
Sorting by an unknown column caused an error.	Only allowed columns can be used for sorting.
Typing % or _ in a search matched everything.	Searches treat these characters as normal text.
Searching on page 3 of Inventory could show an empty page.	A new search goes back to page 1.

7. Dashboard

Problem (before)	What we changed
The dashboard made 9 separate requests. If one of them failed, a whole card went blank ("Analytics unavailable").	The dashboard now makes 1 request. Each part is built separately on the server, so if one part fails only that chart shows "unavailable" - the rest still shows.

8. Broken features that now work

- Invoices: two invoices saved at the same moment could clash on the invoice number. Numbering is now safe.
- Invoices: a finalized invoice could be turned back into a draft and deleted, even though stock was already taken out. This is now blocked.
- Patient profile: the "Book Appointment" button crashed when clicked. It works now.
- Client profile: phone and address changes in the portal were silently not saved. They are saved now.
- Editing an owner could wipe the linked portal account's email and lock the client out. Fixed.
- Sending a message from the patient profile always failed. Fixed.
- System announcements without an end date caused an error. Fixed.
- The server had a "restore backup" address that led nowhere and caused an error. Removed.
- Importing a spreadsheet with a short row crashed the whole import. It now reports the bad row and continues.
- The automated test suite was broken and could not run. It is fixed and expanded to 52 checks.

9. Libraries updated

Outside code packages used by the admin and portal apps had 16 known security warnings (12 serious). They were updated; the live apps now have 0 known warnings. Some warnings remain in build-only tools (Tailwind 3) and need a larger upgrade later.

What staff and clients will notice

Who	Change
Everyone	You will be asked to sign in again after 7 days (was 30).
Everyone	Changing your login email now asks for your current password.
Everyone	Back button and refresh now keep you on the same page of a list.
Veterinarians	Can only create and manage Staff accounts, not admins. Archived "Users" are no longer shown to them.
Front desk staff	Notes typed into diagnosis fields when adding a pet are no longer saved as a medical record. A vet must write it.
Clients	Bookings always wait for clinic approval. Clients can cancel, but not change, an appointment.
Clients	A suspended or deactivated client is stopped immediately, not at next login.
Admins	A finalized invoice can no longer be sent back to draft. Cancel it instead.

Still to do

- Replace the server program the backend runs on ("php artisan serve") with a proper web server. It handles one request at a time and sometimes answers "busy" (error 503) under load.
- Store backups in cloud storage. Render deletes local files whenever the app redeploys.
- Finish the page-by-page browser check of Appointments, Inventory, Invoices, Analytics, Settings and the client portal (needs the portal web address).
- Clean-up of large code files (the dashboard controller) and duplicated code.
- Make sure GOOGLE_CLIENT_ID is set on Render, or Google sign-in will be refused.

How the fixes were checked

- GitHub now runs all 52 checks automatically on every update, plus a library safety check, and marks the update as failed if anything breaks (before, it showed a green tick even when the install failed).
- Every setting the system needs is now listed in one file per app (.env.example), with which ones are required for the live site.
- 52 automated checks run against a real database, covering logins, roles, client limits, clinic separation, error messages, pagination and the dashboard.
- Both apps were built successfully after every change.
- Checked live in the browser on production: the dashboard loads all cards from one request, Back steps through Patients pages 3 to 2 to 1, and all 119 pets appear in the Pet Directory.